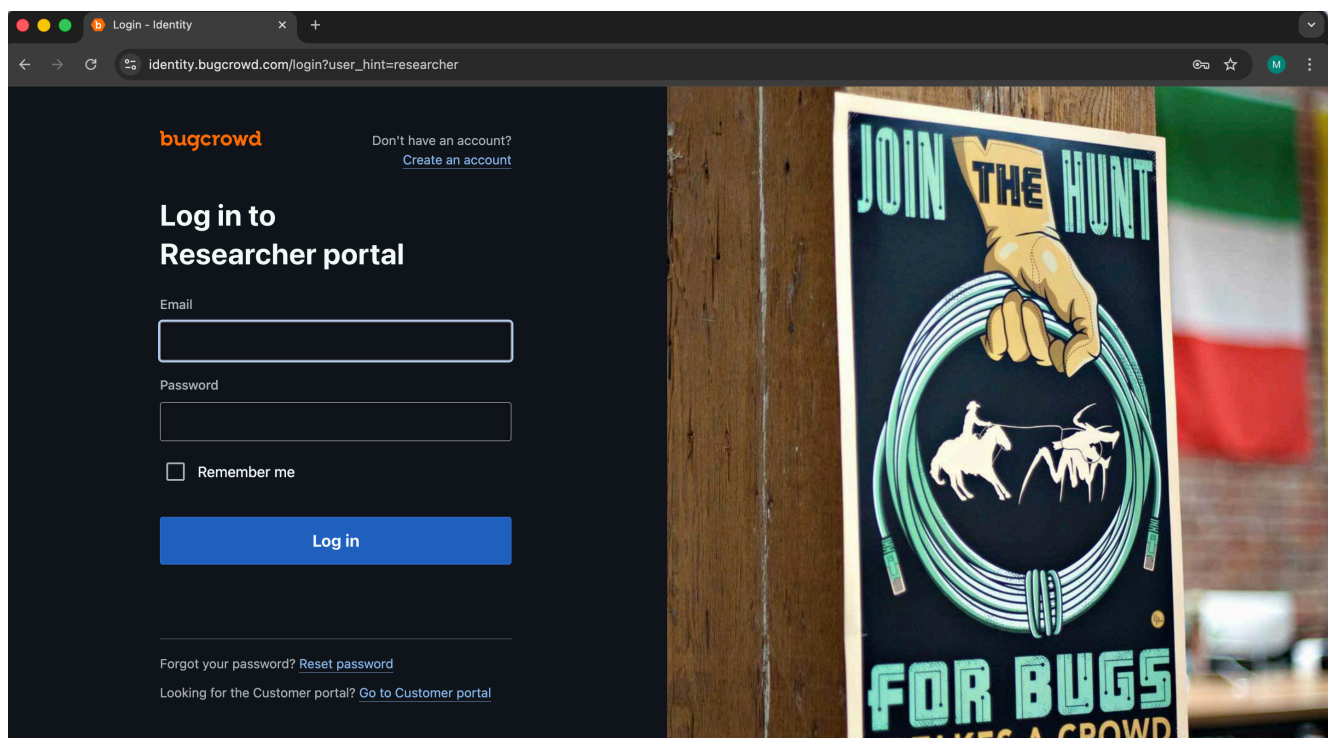
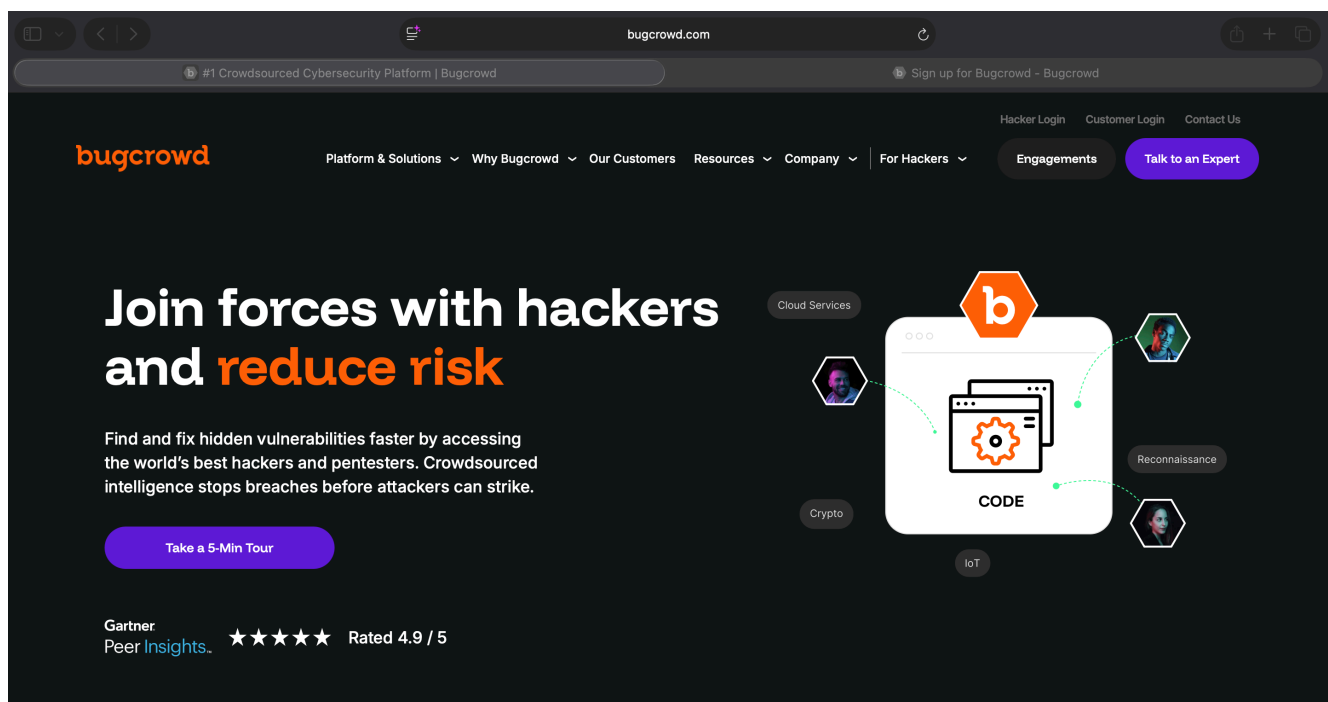


VULNERABILITY ASSESSMENT OF A PUBLIC DISCLOSURE TARGET VIA OWASP ZAP

METHODOLOGY

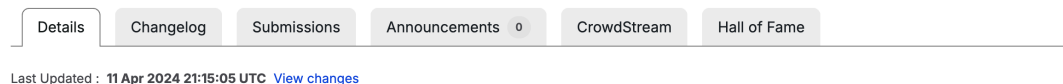
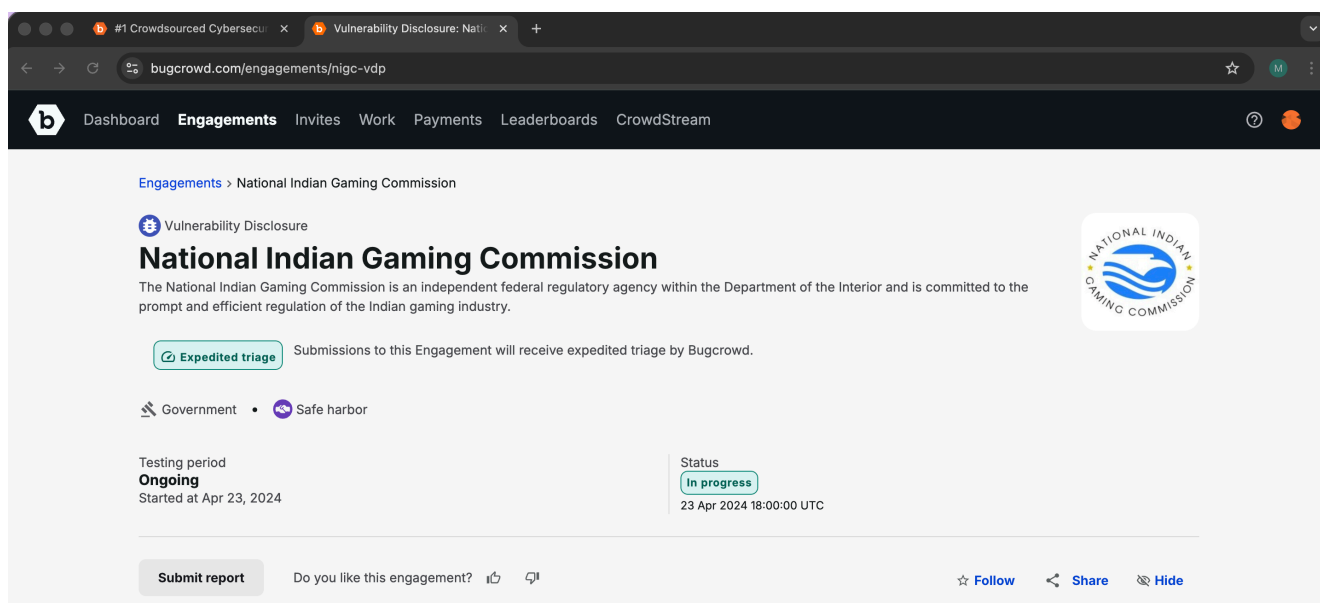
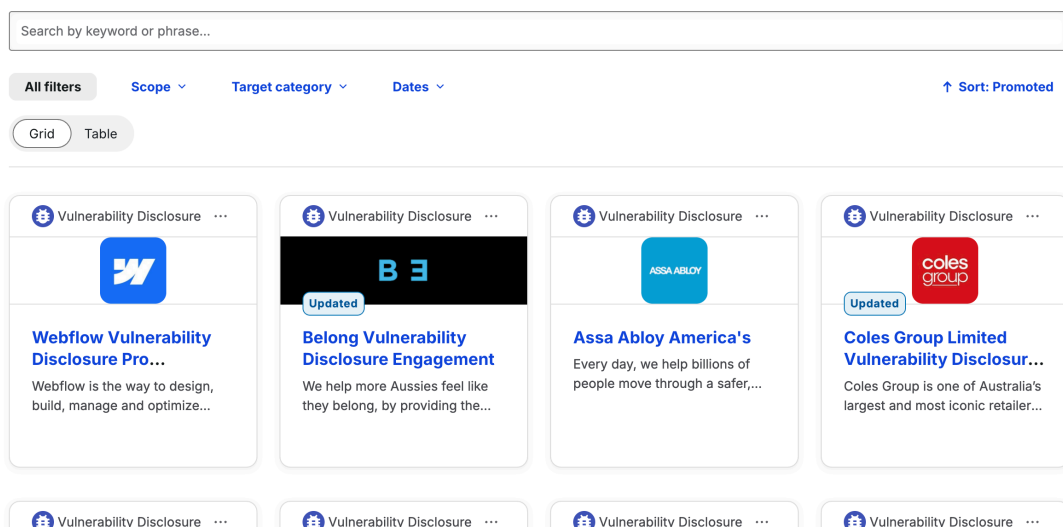
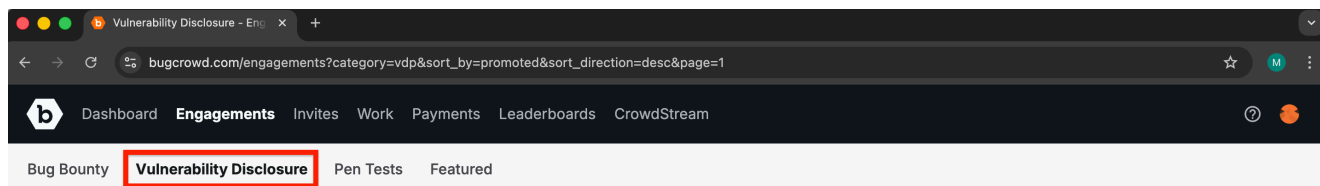
1. Login to Bugcrowd:

- Visit Bugcrowd website and click on Hacker Login
- Enter your credentials to access the Researcher Portal



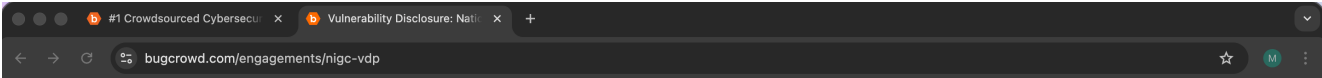
2. Select a Vulnerability Disclosure Program

- Navigate to the Vulnerability Disclosure section.
- Browse available programs and select a target website authorized for testing.



3. Identify Scope and Authorization

- Open the selected program's page and review the Scope section.
- Copy the target domain listed under "In Scope" (e.g., nigc.gov).
- Confirm that your testing activities are authorized under the program's safe harbor policy.



The screenshot shows a web browser with two tabs: "#1 Crowdsourced Cybersecurity" and "Vulnerability Disclosure: National Indian Gaming Commission". The address bar shows the URL `bugcrowd.com/engagements/nigc-vdp`. The page content includes:

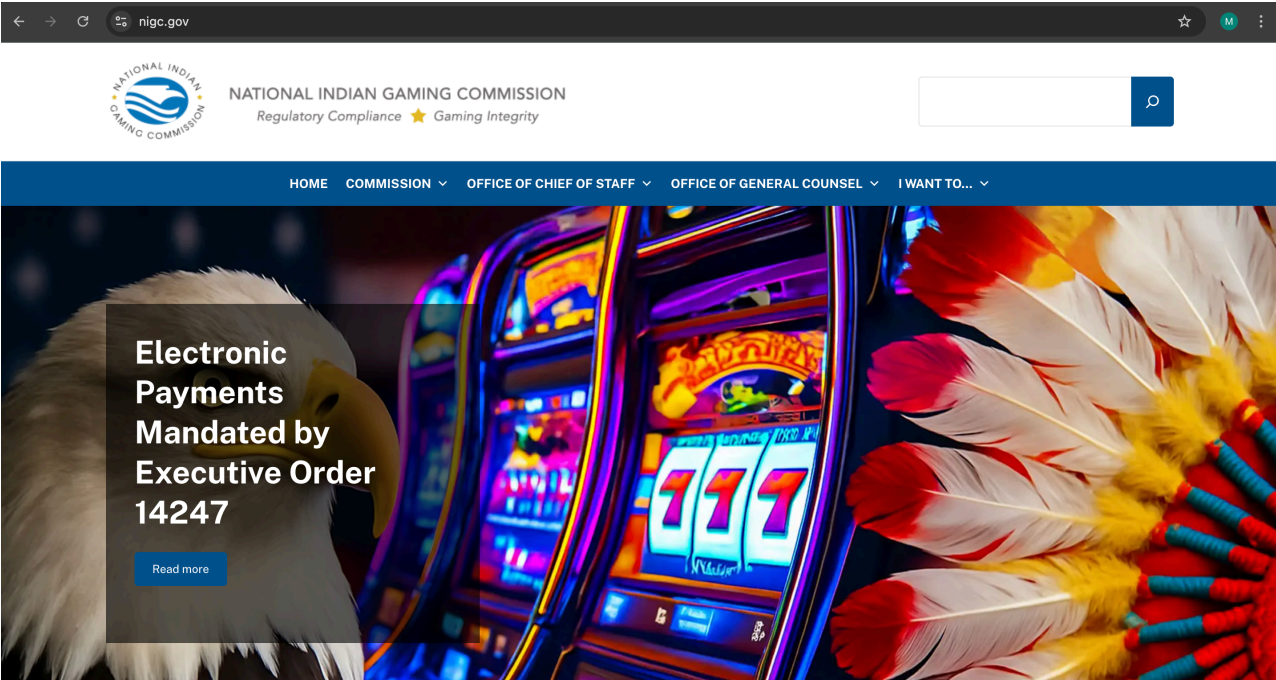
- Authorization**

If you make a good faith effort to comply with this policy during your security research, NIGC will consider your research to be authorized, work with you to understand and resolve the issue quickly and will not recommend or pursue legal action related to your research. Should legal action be initiated by a third party against you for activities that were conducted in accordance with this policy, NIGC will make this authorization known.
- Scope**

In Scope ✓ In scope

*.nigc.gov

Bootstrap jQuery Litespeed HTTPd +3
- On this page**
 - Overview
 - Description
 - Scope
 - What's new
 - Recent activity
 - Things to know
- Support** (button)



The screenshot shows the homepage of the National Indian Gaming Commission (NIGC). The header includes the NIGC logo and the text "NATIONAL INDIAN GAMING COMMISSION Regulatory Compliance Gaming Integrity". The main navigation bar contains links: HOME, COMMISSION, OFFICE OF CHIEF OF STAFF, OFFICE OF GENERAL COUNSEL, and I WANT TO... A large banner image features a slot machine and Native American feathers. Overlaid on the banner is the text "Electronic Payments Mandated by Executive Order 14247" with a "Read more" button.

4. Launch OWASP ZAP in Kali Linux:

- Open your terminal and start ZAP using the command:

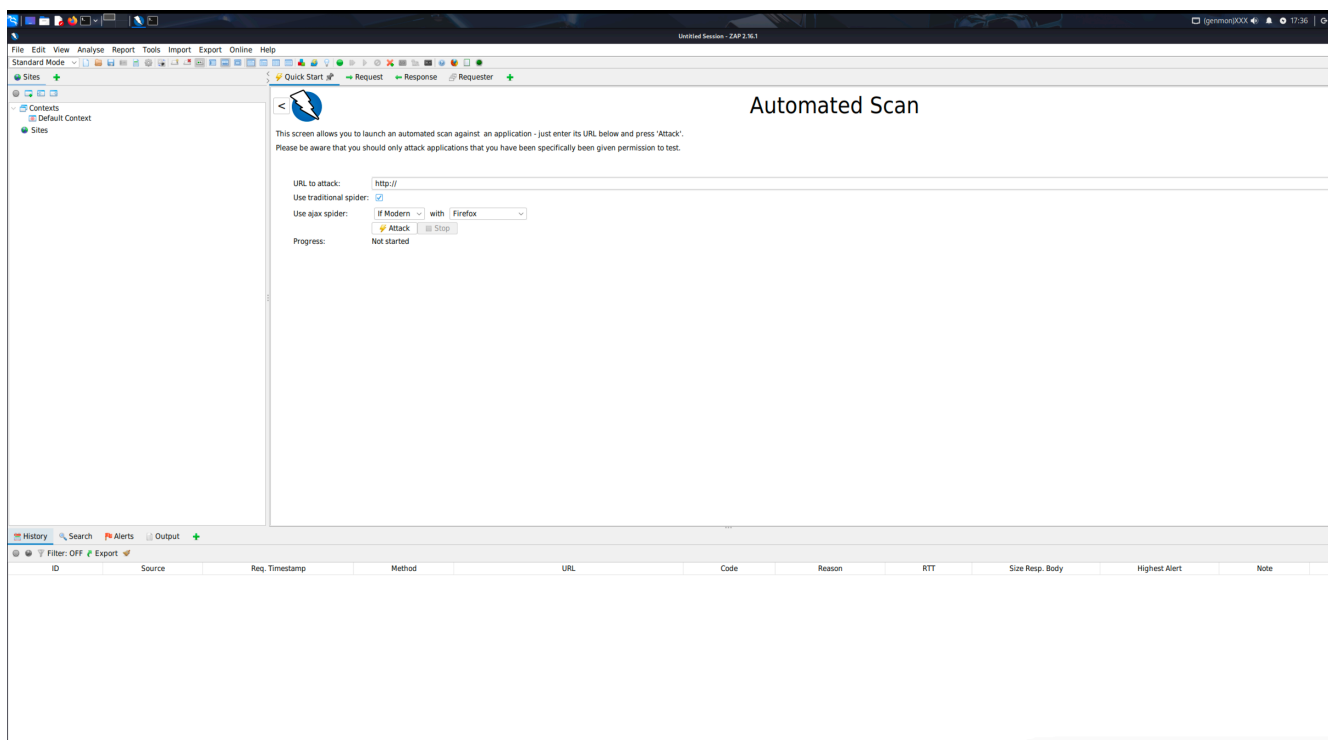
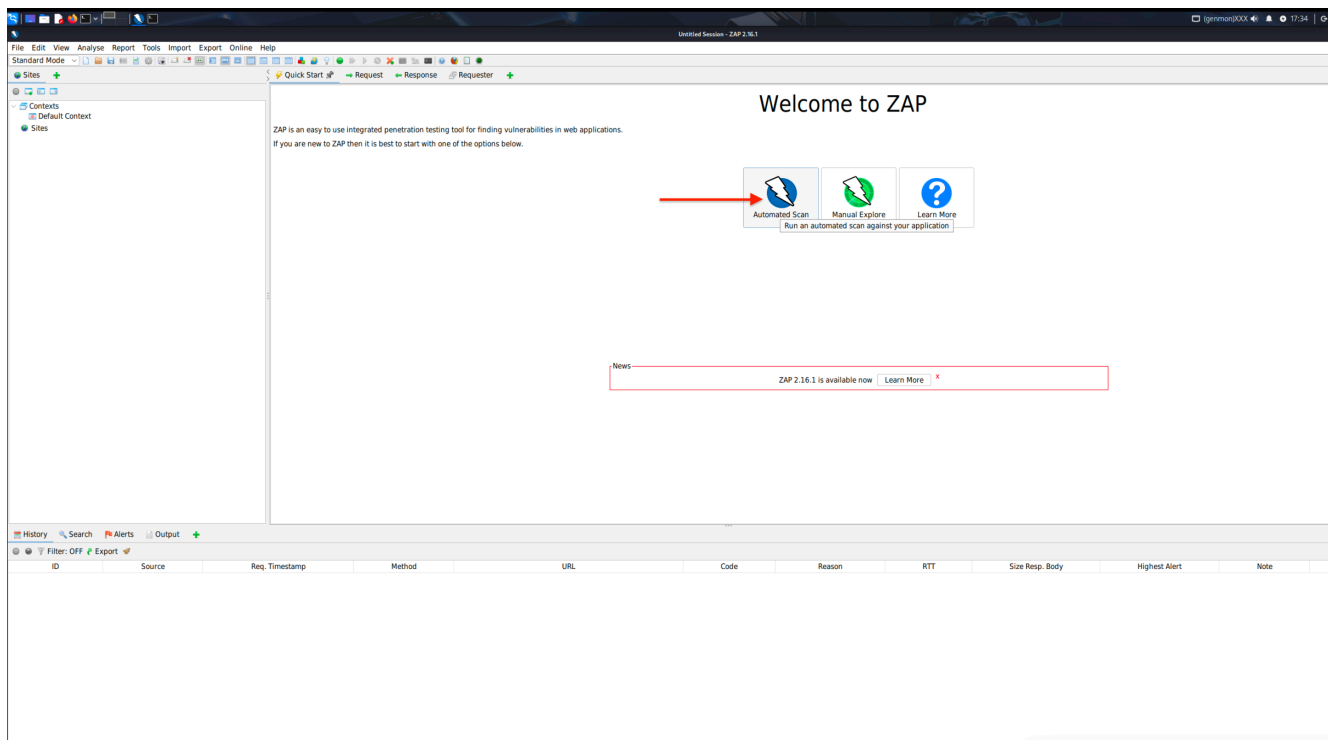
```
root@kali: ~/home/mubassherazaidy
# zaproxy

[main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.16.1 started 15/10/2025, 17:33:35 with home: /root/.ZAP/ cores: 6 maxMemory: 1 GB
[AWT-EventQueue-0] WARN org.zaproxy.zap.GuiBootstrap - Failed to set awt app class name: Unable to make field private static java.lang.String sun.awt.X11.XToolkit.awtAppClassName accessible: module java.desktop does not "opens sun.awt.X11" to unnamed module 82f490758
[AWT-EventQueue-0] INFO org.parosproxy.paros.view.View - Initialising View
[ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Installed add-ons: [[id=alertFilters, version=23.0.0], [id=automation, version=0.53.0], [id=bruteforce, version=18.0.0], [id=calhorne, version=0.14.0], [id=client, version=0.15.0], [id=commonlib, version=1.31.0], [id=database, version=0.8.0], [id=diff, version=17.0.0], [id=directorylistv1, version=9.0.0], [id=encoder, version=1.6.0], [id=exml, version=0.15.0], [id=formhandler, version=6.7.0], [id=fuzz, version=13.16.0], [id=gettingStarted, version=19.0.0], [id=graphql, version=0.28.0], [id=help, version=20.0.0], [id=hud, version=0.19.0], [id=invoke, version=16.0.0], [id=network, version=0.21.0], [id=oast, version=0.21.0], [id=onlineMenu, version=14.0.0], [id=openapi, version=45.0.0], [id=postman, version=0.7.0], [id=pscan, version=0.2.1], [id=quickstart, version=51.0.0], [id=replacer, version=20.0.0], [id=reports, version=0.38.0], [id=requester, version=7.8.0], [id=retest, version=0.11.0], [id=retire, version=0.46.0], [id=reveal, version=10.0.0], [id=scanpolicies, version=0.2.0], [id=scripts, version=45.9.0], [id=selenium, version=15.36.0], [id=sequence, version=8.0.0], [id=soap, version=24.0.0], [id=spider, version=0.14.0], [id=spiderAjax, version=23.23.0], [id=tips, version=14.0.0], [id=webdriverlinux, version=159.0.0], [id=websocket, version=33.0.0], [id=zest, version=48.9.0]]
[ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Loading extensions
[ZAP-BootstrapGUI] INFO org.zaproxy.addon.network.internal.TlsUtils - Using suite 2, TLSv1.3]
[ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Extensions
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Anti-CSRF Extension - Handles anti cross site request forgery (CSRF) tokens
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Authentication Extension - Authentication Extension
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising AuthenticationExtension - Loaded authentication method types: [Form-based Authentication, HTTP/NTLM Authentication, Manual Authentication, Script-based Authentication, JSON-based Authentication]
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Users Extension - Users Extension
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Parameters Extension - Summarise and analyse FORM and URL parameters as well as cookies
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Script Extension - Script integration
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionScripts - Scripting console, supports all JSR 223 scripting languages
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Forced User Extension - Forced User Extension
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising HTTP Sessions Extension - Extension handling HTTP sessions
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionZest - Zest is a specialized scripting language, originally, from Mozilla specifically designed to be used in security tools
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionDiff - ExtensionDiff
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising HTTP Panel Post Table View Extension - HTTP Panel Post Table View Extension
[ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Encoder Addon - Adds support for scriptable encoders to ZAP.
```

```
Found Java version 21.0.9-ea
Available memory: 6900 MB
Using JVM args: -Xmx1725m
329 [main] WARN org.zaproxy.zap.ZapBootstrap - ZAP is being run using the root user - this is NOT recommended!
336 [main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.16.1 started 15/10/2025, 17:33:35 with home: /root/.ZAP/ cores: 6 maxMemory: 1 GB
396 [AWT-EventQueue-0] WARN org.zaproxy.zap.GuiBootstrap - Failed to set awt app class name: Unable to make field private static java.lang.String sun.awt.X11.XToolkit.awtAppClassName accessible: module java.desktop does not "opens sun.awt.X11" to unnamed module 82f490758
1683 [AWT-EventQueue-0] INFO org.parosproxy.paros.view.View - Initialising View
1681 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Installed add-ons: [[id=alertFilters, version=23.0.0], [id=automation, version=0.53.0], [id=bruteforce, version=18.0.0], [id=calhorne, version=0.14.0], [id=client, version=0.15.0], [id=commonlib, version=1.31.0], [id=database, version=0.8.0], [id=diff, version=17.0.0], [id=directorylistv1, version=9.0.0], [id=encoder, version=1.6.0], [id=exml, version=0.15.0], [id=formhandler, version=6.7.0], [id=fuzz, version=13.16.0], [id=gettingStarted, version=19.0.0], [id=graphql, version=0.28.0], [id=help, version=20.0.0], [id=hud, version=0.19.0], [id=invoke, version=16.0.0], [id=network, version=0.21.0], [id=oast, version=0.21.0], [id=onlineMenu, version=14.0.0], [id=openapi, version=45.0.0], [id=postman, version=0.7.0], [id=pscan, version=0.2.1], [id=quickstart, version=51.0.0], [id=replacer, version=20.0.0], [id=reports, version=0.38.0], [id=requester, version=7.8.0], [id=retest, version=0.11.0], [id=retire, version=0.46.0], [id=reveal, version=10.0.0], [id=scanpolicies, version=0.2.0], [id=scripts, version=45.9.0], [id=selenium, version=15.36.0], [id=sequence, version=8.0.0], [id=soap, version=24.0.0], [id=spider, version=0.14.0], [id=spiderAjax, version=23.23.0], [id=tips, version=14.0.0], [id=webdriverlinux, version=159.0.0], [id=websocket, version=33.0.0], [id=zest, version=48.9.0]]
1683 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Loading extensions
1978 [ZAP-BootstrapGUI] INFO org.zaproxy.addon.network.internal.TlsUtils - Using suite 2, TLSv1.3]
2149 [ZAP-BootstrapGUI] INFO org.zaproxy.zap.control.ExtensionFactory - Extensions
2609 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Anti-CSRF Extension - Handles anti cross site request forgery (CSRF) tokens
2645 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Authentication Extension - Authentication Extension
2780 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising AuthenticationExtension - Loaded authentication method types: [Form-based Authentication, HTTP/NTLM Authentication, Manual Authentication, Script-based Authentication, JSON-based Authentication]
2783 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Users Extension - Users Extension
2798 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Parameters Extension - Summarise and analyse FORM and URL parameters as well as cookies
2855 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Script Extension - Script integration
2859 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionScripts - Scripting console, supports all JSR 223 scripting languages
2892 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Forced User Extension - Forced User Extension
2943 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising HTTP Sessions Extension - Extension handling HTTP sessions
2945 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionZest - Zest is a specialized scripting language, originally, from Mozilla specifically designed to be used in security tools
3057 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising ExtensionDiff - ExtensionDiff
3100 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising HTTP Panel Post Table View Extension - HTTP Panel Post Table View Extension
3104 [ZAP-BootstrapGUI] INFO org.parosproxy.paros.extension.ExtensionLoader - Initialising Encoder Addon - Adds support for scriptable encoders to ZAP.
3108 [ZAP-BootstrapGUI] INFO
3135 [ZAP-BootstrapGUI] INFO
3137 [ZAP-BootstrapGUI] INFO
3147 [ZAP-BootstrapGUI] INFO
3156 [ZAP-BootstrapGUI] INFO
3167 [ZAP-BootstrapGUI] INFO
```

5. Initiate an Automated Scan

- In ZAP, go to Quick Start and select **Automated Scan**.



6. Initiate Scan :

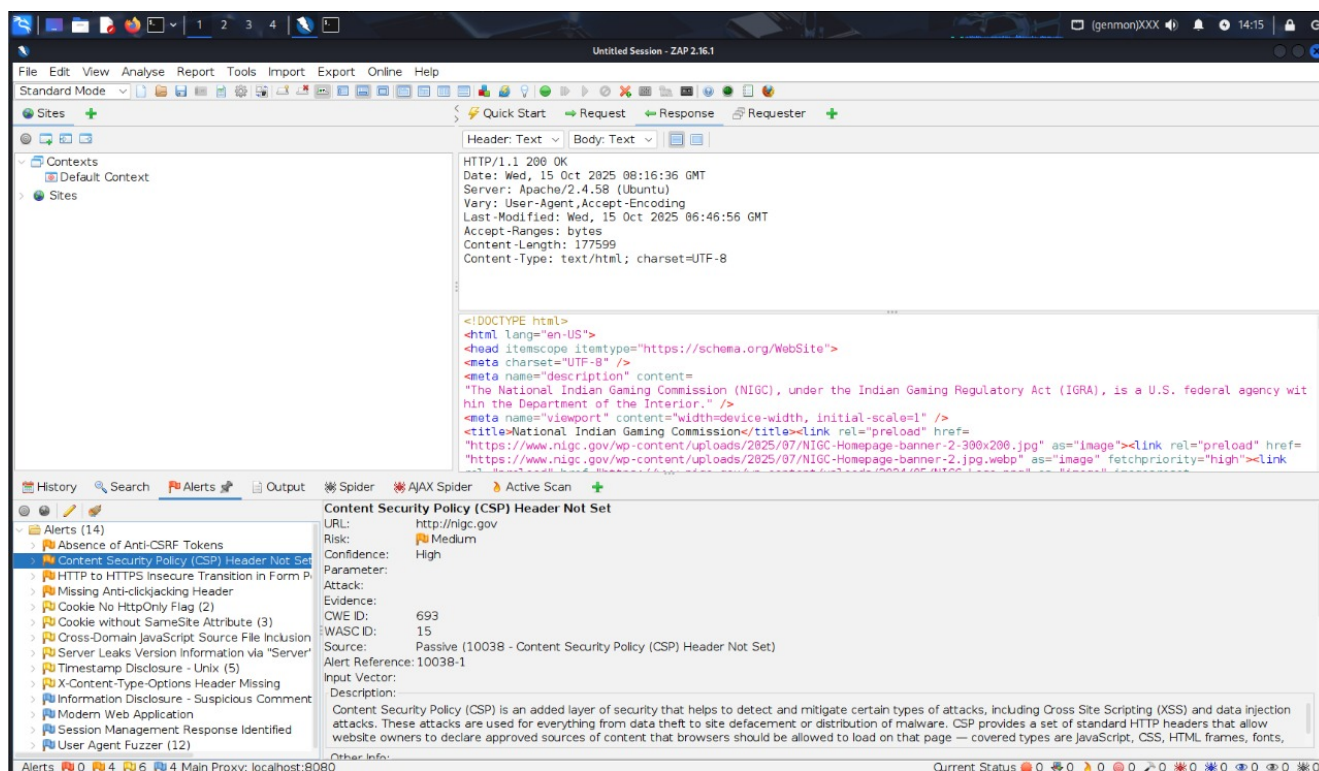
- Paste the target URL into the scan field.
- Click **Attack** to begin scanning.

The screenshot shows the ZAP 2.16.1 interface during an automated scan. The 'Automated Scan' window is active, displaying the URL 'http://nigc.gov' and the progress bar at 12%. Below the scan controls, a table lists the scan results for various URLs, all of which returned a 404 Not Found status.

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
9	15/10/25, 1:46:57 pm	15/10/25, 1:46:58 pm	GET	http://nigc.gov/1775981902177117450	404	Not Found	991 ms	161 bytes	270 bytes
11	15/10/25, 1:46:58 pm	15/10/25, 1:46:59 pm	GET	http://nigc.gov/WEB-INF/web.xml	404	Not Found	891 ms	161 bytes	270 bytes
12	15/10/25, 1:46:59 pm	15/10/25, 1:47:00 pm	GET	http://nigc.gov/WEB-INF/applicationContext.xml	404	Not Found	494 ms	161 bytes	270 bytes
13	15/10/25, 1:47:00 pm	15/10/25, 1:47:00 pm	GET	http://nigc.gov/WEB-INF/classes/2/0.class	404	Not Found	506 ms	161 bytes	270 bytes
14	15/10/25, 1:47:00 pm	15/10/25, 1:47:00 pm	GET	http://nigc.gov/WEB-INF/classes/2/4/58.class	404	Not Found	408 ms	161 bytes	270 bytes
15	15/10/25, 1:47:01 pm	15/10/25, 1:47:01 pm	GET	http://nigc.gov/WEB-INF/classes/nigc/gov.class	404	Not Found	502 ms	161 bytes	270 bytes
16	15/10/25, 1:47:03 pm	15/10/25, 1:47:04 pm	POST	http://nigc.gov/robots.txt?-d+allow_url_include%3...	404	Not Found	493 ms	161 bytes	270 bytes
17	15/10/25, 1:47:03 pm	15/10/25, 1:47:04 pm	POST	http://nigc.gov/sitemap.xml?-d+allow_url_include%3...	404	Not Found	1.16 s	161 bytes	270 bytes
18	15/10/25, 1:47:04 pm	15/10/25, 1:47:04 pm	POST	http://nigc.gov/robots.txt?-d+allow_url_include%3...	404	Not Found	672 ms	161 bytes	270 bytes

7. Review Discovered Vulnerabilities:

- Once the scan completes, navigate to the **Alerts** tab.
- Review all identified issues, including:
 - Missing Content Security Policy (CSP) headers
 - Absence of Anti-CSRF tokens
 - Insecure HTTP-to-HTTPS transitions
 - Missing anti-clickjacking headers
 - Server version disclosure
 - Timestamp and comment-based information leaks



8. Submit Your Report

- Return to the Bugcrowd program page and click **Submit Report**.
- Fill in the vulnerability details, attach proof-of-concept files (screenshots, scripts, etc.), and confirm adherence to Bugcrowd's terms.

The screenshot shows the Bugcrowd engagement page for the National Indian Gaming Commission. The page header includes the engagement name and a 'Vulnerability Disclosure' badge. The main title is 'National Indian Gaming Commission' with a sub-header stating it is an independent federal regulatory agency. A green 'Expedited triage' badge indicates that submissions will receive expedited triage. Below this, there are tags for 'Government' and 'Safe harbor'. The 'Testing period' is 'Ongoing' and 'Started at Apr 23, 2024'. The 'Status' is 'In progress' with a timestamp of '23 Apr 2024 18:00:00 UTC'. A red arrow points to the 'Submit report' button. Other buttons include 'Follow', 'Share', and 'Hide'. At the bottom, there are tabs for 'Details', 'Changelog', 'Submissions', 'Announcements', 'CrowdStream', and 'Hall of Fame'. A 'Support' button is also visible.

The screenshot shows the Bugcrowd submission form for the National Indian Gaming Commission. The form is titled 'Submit a report to National Indian Gaming Commission'. It includes instructions on how to attach proof-of-concept scripts, screenshots, and screen recordings, and how to embed attachments into the Markdown fields. The form is divided into sections: 'Collaborate (optional)' with a field for 'Add researchers and collaborate on this submission', 'Confirmation' with a checkbox for 'I have followed the brief and agree to Bugcrowd's terms & conditions', and a 'Report vulnerability' button. At the bottom, there are buttons for 'Save draft', 'Delete', and 'Saved a few seconds ago'.

Result :

The OWASP ZAP automated scan against the authorized target domain (nigc.gov) successfully completed and revealed multiple security vulnerabilities.